LESSON 6.1.3

AI Governance

How organizations structure people, processes, and controls to implement AI safely and responsibly.

Three Core Layers

Risks & Controls

Key Roles

Three Layers of AI Governance

Every AI system operates across three distinct swim lanes, each with its own risks and responsibilities.

Data Layer

Training datasets, logs, privacy exposure

Code Layer

Libraries, dependencies, injection risks

Architecture Layer

Identity, access control, API security

LAYER 1

The Data Layer

The Opportunity

Organizations have accumulated massive logs and activity data. AI helps make sense of it all but only with proper curation.

The Risks

- Private or regulated data inadvertently in training sets
- Vulnerability scan data exposed to the model
- Hidden biases surfacing in AI outputs

Mixing all data without governance = **total privacy nightmare**

LAYER 2

The Code Layer

Speed of AI development using third-party libraries introduces serious security vulnerabilities.

Malicious Libraries

Unvetted Python packages can introduce **backdoors** into AI systems, compromising data integrity.

Code Manipulation

Developers must understand how code can be altered to **access protected or sensitive data**.

Prompt Injection Attacks

Crafted inputs can **bypass guardrails** and extract confidential corporate information from AI models.

LAYER 3

The Architecture Layer

Access control is the cornerstone for **humans, APIs, cloud resources, and datasets alike.**

RBAC

Role-Based Access Control

ABAC

Attribute-Based Access Control

DAC

Discretionary Access Control

IAM

Identity Access Management

Key Roles in AI Governance

Specialization is essential — no single person can own all of AI's complexity.

AI Security Architect

Designs the access and protection model for AI systems

Governance Engineer

Implements RBAC and ABAC controls defined by the architect

AI Auditor

Independently verifies that controls are working as documented

Cross-Skilling Matters

Why It's Essential

AI decisions ripple across all domains. Team members must understand each other's work to catch risks early.

The Specialization Balance

AI evolves too rapidly for generalists alone.

- Deep expertise in each layer is required
- But siloed teams create blind spots
- Cross-domain fluency builds resilience

The Auditor's Challenge

Staying current is one of the hardest parts of AI compliance work.

1 Verify Controls

Confirm RBAC/ABAC rules match documentation

2 Track Privacy Laws

Monitor shifting global data regulations

3 Follow AI Legislation

Adapt to emerging AI oversight frameworks

4 Report Findings

Deliver independent, unbiased compliance assessments

The regulatory landscape is **constantly evolving** — AI auditors must be continuous learners.

Key Takeaways

1 **Governance is the glue**

It unifies data science, coding, and architecture under a shared risk framework.

2 **Three layers, three risk surfaces**

Data, Code, and Architecture each carry distinct threats requiring distinct controls.

3 **Roles must be specialized**

Architect → Engineer → Auditor: a clear chain of design, implementation, and verification.

4 **Cross-skilling is non-negotiable**

AI affects everyone — teams that understand each other's domains make safer decisions.